

1.9 Create Use Case and Rules

Use Case : Account Compromise Attempts

1. Overview

This use case aims to detect activities that may indicate an attempt to compromise user accounts.

It includes multiple detection rules covering different attack patterns such as brute-force login attempts, suspicious geographic login activity, and abnormal password reset behavior.

2. Use Case: Account Compromise Attempts

2.1 Details

- ♦ **Name:** Account Compromise Attempts
 - ♦ **Description:**
Detects suspicious authentication patterns that may indicate attempted account compromise, including multiple login failures, logins from unusual countries, and abnormal password reset activity.
 - ♦ **Severity:** Medium–High
 - ♦ **Risk Score:** 60
 - ♦ **Tags:**
 - ♦ account
 - ♦ authentication
 - ♦ compromise
-

2.2 MITRE ATT&CK Mapping

Technique ID	Name
T1110	Brute Force
T1110.001	Password Guessing
T1078	Valid Accounts

2.3 Owner

- ◆ DEPI-Security Team

2.4 Purpose

This use case groups multiple detection rules under Account Compromise Attempts to simplify monitoring, triage, and investigation.

Security

Cases

Create

Add Integrations

2

Case fields

Name

Account Compromise Attempts

Tags

Optional

account × authentication × compromise × T1078 (valid accounts) × T110 (Brute force) × T1110.001 - Password Guessing ×

Separate tags with a line break.

Category

Optional

Authentication

Severity

Medium

Description

B I [List Icons] [Quote Icon] [Code Icon] [Link Icon] [Comment Icon] [More Icon]

Preview

Detection of suspicious activities indicating possible account compromise such as multiple login failures, unusual geo login, or abnormal password reset activities.

3. Detection Rules Inside This Use Case

This Use Case contains the following three rules:

1. Multiple Login Failures (Brute Force Indicator)
2. Login From Unusual Country (Suspicious Geo-Login)
3. Unusual Password Reset Activity (Password Reset Abuse)

Each rule is documented below with full configuration steps.

4. Rule 1: Multiple Login Failures

4.1 Objective

Detects when a user experiences an unusually high number of failed login attempts in a short time, indicating possible brute-force activity.

4.2 How to Create the Rule

Steps

1. Go to:
Security → Rules → Create new rule
2. Select:
Threshold Rule
3. Under **Define Rule**, enter this KQL query:

```
event.category: authentication AND event.outcome: failure AND (  
  event.code: 4625 OR  
  winlog.event_id: 4625 OR  
  event.code: 1006)
```

4. Scroll to the **Threshold** section and configure:

- **Field:** user.name
- **Threshold:** 10
- **Time window:** 5 minutes

The screenshot shows the Kibana Security Rules configuration interface for a Threshold Rule. The 'Source' section is set to 'Index Patterns'. The 'Index patterns' field contains 'auditbeat-*', 'filebeat-*', 'logs-*', and 'winlogbeat-*'. The 'Custom query' field contains the KQL query: 'event.category: authentication AND event.outcome: failure AND (event.code: 4625 OR winlog.event_id: 4625 OR event.code: 1006)'. The 'Group by' field is set to 'host.name'. The 'Threshold' field is set to '5'. The 'Count' field is set to 'All results'. The 'Unique values' field is empty. The 'Suppress alerts by selected fields' section is checked, with 'host.name' selected. The 'Per time period' option is selected, with a value of '5' and the unit 'Minutes'.

Source

Use Kibana [Data Views](#) or specify individual [index patterns](#) as your rule's data source to be searched.

☒ Index Patterns ☐ Data View

Index patterns [Reset to default index patterns](#)

auditbeat-* × filebeat-* × logs-* × winlogbeat-* ×

Enter the pattern of Elasticsearch indices where you would like this rule to run. By default, these will include index patterns defined in Security Solution advanced settings.

Custom query [Import query from saved timeline](#)

event.category: authentication AND event.outcome: failure AND (
event.code: 4625 OR
winlog.event_id: 4625 OR
event.code: 1006)

Group by

host.name ×

Threshold

5

Select fields to group by. Fields are joined together with 'AND'

Count

All results

Unique values

Select a field to check cardinality

☒ Suppress alerts by selected fields: host.name

☐ Per rule execution

☒ Per time period

5 Minutes

4.3 Metadata (About Section)

- **Rule Name:** Failed User Logon Multiple Times Detection
- **Severity:** Hight
- **Risk Score:** 73
- **Tags:**
 - authentication
 - bruteforce
 - account
- **Reference URL** <https://attack.mitre.org/techniques/T1110/>

MITRE ATT&CK Tactics :

- **Credential Access (TA0006)**
- **Brute Force (T1110)**

2

About rule

Name

Failed User Logon Multiple Times Detection

Description

This rule detects repeated failed logon attempts from the same user within a short time window. Multiple authentication failures may indicate brute-force attempts, credential stuffing, or a compromised system trying to escalate access.

Default severity

Select a severity level for all alerts generated by this rule.

High

☐ Severity override

Use source event values to override the default severity.

Default risk score

Select a risk score for all alerts generated by this rule.

0255075100

73

☐ Risk score override

Use a source event value to override the default risk score.

Tags

Optional

Tags

Optional

authentication ×

bruteforce ×

account ×

brute-force ×

windows ×

T1110 ×



Type one or more custom identifying tags for this rule. Press enter after each tag to begin a new one.

Advanced settings

Reference URLs

Optional

<https://attack.mitre.org/techniques/T1110/>



+ Add reference URL

False positive examples

Optional



+ Add false positive example

MITRE ATT&CK™ threats

Optional

MITRE ATT&CK™ tactic

Credential Access (TA0006)



MITRE ATT&CK™ technique

Brute Force (T1110)



+ Add subtechnique

+ Add technique

+ Add tactic

Schedule rule



3

Schedule rule

Runs every

5



Minutes



Rules run periodically and detect alerts within the specified time frame.

Additional look-back time

10



Minutes



Adds time to the look-back period to prevent missed alerts.

Continue

4.4 Save & Enable the Rule

Failed User Logon Multiple Times Detection

Created by: elastic on Nov 27, 2025 @ 22:22:10.745 Updated by: elastic on Nov 27, 2025 @ 22:23:14.773

Last response: ● succeeded at Nov 27, 2025 @ 22:22:13.400 Notify when alerts generated



Enable

Edit rule settings



About

Description

This rule detects repeated failed logon attempts from the same user within a short time window. Multiple authentication failures may indicate brute-force attempts, credential stuffing, or a compromised system trying to escalate access.

Author

Ramadan

Severity

High

Risk score

73

Reference URLs

<https://attack.mitre.org/techniques/T1110/>

MITRE ATT&CK™

Credential Access (TA0006)
Brute Force (T1110)

Max alerts per run

100

Tags

authentication brute-force account
brute-force windows T1110

Definition

Index patterns

apm-* transaction* auditbeat-* endgame-*
filebeat-* logs-* packetbeat-*
traces-apm* winlogbeat-*
-*elastic-cloud-logs-*

Custom query

event.category: authentication AND
event.outcome: failure AND (
event.code: 4625 OR
winlog.event_id: 4625 OR
event.code: 1006)

Custom query language

KQL

Rule type

Threshold

Required fields

host.name,
@timestamp,
host.ip,
user.name

Timeline template

Alerts Involving a Single User Timeline

Threshold

Results aggregated by host.name >= 5

Schedule

Runs every

5m

5. Rule 2: Login From Unusual Country

5.1 Objective

Detects successful logins from countries that are not typically associated with the organization's user base.

This may indicate credential theft or account compromise.

5.2 How to Create the Rule

Steps

- Go to:
Security → Rules → Create new rule
- Select:
Custom Query Rule

3- In **Define Rule**, enter the query:

```
event.category: authentication AND event.outcome: success AND NOT  
source.geo.country_iso_code : ("EG" OR "SA" OR "AE")
```

(Replace the allowed countries with your expected baseline.)

5.3 Metadata

- **Rule Name:** Login From Unusual Country
 - **Severity:** High
 - **Risk Score:** 75
 - **Tags:**
 - ♦ geoip
 - ♦ authentication
 - ♦ account
 - ♦ suspicious
 - ♦ **Associated Use Case:**
Account Compromise Attempts
-

5.4 Save & Enable the Rule

6. Rule 3: Unusual Password Reset Activity

6.1 Objective

Detects repeated or abnormal password reset attempts for the same user within a small time window.

6.2 How to Create the Rule

Steps

1. Navigate to:
Security → Rules → Create new rule
2. Select:
Custom Query Rule
3. Use the following query:

(event.action: "password_reset" OR event.type: "change_password")
OR winlog.event_id: (4723, 4724)

4. Configure the **Threshold**:

- **Field:** user.name
- **Threshold:** 3
- **Time window:** 10 minutes

6.3 Metadata

- **Rule Name:** Unusual Password Reset Activity
- **Severity:** Medium
- **Risk Score:** 60
- **Tags:**
 - ♦ password
 - ♦ reset
 - ♦ account
- ♦ **Associated Use Case:**
Account Compromise Attempts

Unusual Password Reset Activity

Created by: elastic on Nov 28, 2025 @ 14:01:50.635 Updated by: elastic on Nov 28, 2025 @ 14:05:21.764
Last response: ● succeeded at Nov 28, 2025 @ 14:01:52.294   Notify when alerts generated



Enable

 Edit rule settings



About

Description

Multiple password resets in a short period strongly indicate attempts to obtain or take control of user credentials.

Author

Ramadan

Severity

● Medium

Risk score

47

MITRE ATT&CK™

Credential Access (TA0006) 

Max alerts per run

100

Tags

password-reset account authentication

Definition

Index patterns

apm-*transaction* auditbeat-* endgame-*
filebeat-* logs-* packetbeat-* traces-apm*
winlogbeat-* -*elastic-cloud-logs-*

Custom query

(event.action: "password_reset" OR event.type: "change_password")
OR winlog.event_id: (4723, 4724)

Custom query language

KQL

Rule type

Threshold

Timeline template

Generic Endpoint Timeline

Threshold

Results aggregated by user.name >= 3

Schedule

Runs every

10m

Additional look-back time

20m

6.4 Save & Enable the Rule

Use Case: Account Compromise Attempts

Contains 3 Rules:

Rule Name	Purpose	Severity
Multiple Login Failures	Detect brute-force attempts	Medium
Login From Unusual Country	Detect suspicious geolocation logins	High
Unusual Password Reset Activity	Detect abnormal reset attempts	Medium
